

Agentic Wallet Guardian

A Decision Layer for Autonomous On-Chain Agents

rudimentall1 · August 2026 · v3.1

Abstract

As AI agents are given wallets and permission to transact, the gap between what an agent claims it will do and what a transaction actually does becomes a real financial risk. Agentic Wallet Guardian is a self-hosted decision layer that evaluates a proposed on-chain action and returns an explainable ALLOW, WARN, or BLOCK before anything is signed — without ever touching a private key. This paper describes the system's architecture, the specific failure modes it targets, and, in the interest of not overstating a young project, exactly what is and is not yet built.

1. The Problem

An autonomous agent that can propose blockchain transactions introduces a specific and underappreciated risk: the gap between stated intent and actual on-chain effect. An agent may report "approving 500 USDC" while the transaction it is about to sign encodes an approval for 5,000 — a 900% discrepancy that most guardrails, which only check for near-unlimited approvals, never catch.

This is compounded by three further problems: agents acting outside their own established behavioral pattern (a wallet that has only ever sent \$100 transfers suddenly proposing \$50,000), agents interacting with contracts of unknown provenance, and the complete absence of a way for a third party to later verify that a given decision was genuinely made by the policy engine and not altered after the fact.

2. System Architecture

Guardian evaluates every proposed action through an eleven-stage pipeline, each stage contributing independent signals that are fused into a single 0–100 risk score and a final decision.

#	Stage	Purpose
1	Hard Rules	Chain support and basic sanity checks
2	Wallet Intelligence	Wallet age, contract-vs-EOA, transaction history
3	Token Intelligence	Liquidity, market data
4	Contract Intelligence	Verification status, upgradeability, known-bad lists
5	Simulation	Real eth_call dry-run against the actual target contract
6	Threat Intelligence	OFAC-sourced sanctioned-address matching
7	Anomaly Detection	Deviation from this specific agent's own history
8	Policy Engine	Operator-configured spending caps and capability limits
9	Risk Fusion	Weighted combination of every signal above
10	Reputation Adjustment	Agent trust score from decision history
11	Explanation	Evidence translated into a human-readable reason

Two design properties hold throughout every stage. First, Guardian never holds or requests a private key — it is a decision function, not a custody or signing layer, and remains chain-agnostic by construction. Second, and more specific to this project: when a value cannot be determined with confidence — a token's decimals, a swap's expected output, an agent's historical baseline — the system reports that uncertainty honestly rather than assuming a default. A wrong guess in a security tool is worse than a visible gap.

3. Intent Verification and Anomaly Detection

3.1 Intent vs. calldata

Where most guardrails check only for unlimited-approval patterns, Guardian's intent verification module decodes the actual calldata of a proposed transaction and compares it against what the agent declared. A finite but incorrect amount — the 500-vs-5,000 case above — is caught here, not treated as a variant of the unlimited-approval check.

```
Case: agent said 500, calldata actually encodes 5000
[BLOCK] Agent declared an approval of 500 (5000000000 atomic units),
      but the actual calldata encodes 50000000000 atomic units -
      a 900% difference.
```

This transaction does not do what the agent said it would do.

Live output from examples/example_intent_verification.py.

3.2 Deviation from an agent's own history

A separate module compares a proposed action against the agent's own recorded history — a new action type it has never performed, a chain it has never transacted on, or an amount that is a statistical outlier relative to its past behavior, computed as a z-score against the agent's own mean and standard deviation. This is distinct from reputation (a single trust score) and from policy (static, operator-set limits): an action can be within policy and from a well-reputed agent while still being wildly atypical for that agent specifically. With fewer than five prior data points, the system reports insufficient history rather than fabricating a baseline.

4. Verifiable Decisions: OAA

Every decision Guardian returns is signed as an OAA (Open Agent Attestation) token — an Ed25519-signed JWT wrapping the decision, the action, and the policy reference. Anyone holding the corresponding public key can verify the decision offline, with no dependency on the server that issued it and no requirement to trust whoever is presenting the token.

```
decision: BLOCK
```

```
OAA token:
```

```
eyJhbGciOiJIJFZERTQSIiInR5cCI6IkpXVCJ9.eyJpc3Mi...vodRYGs_vyNt
```

```
verified by a third party (offline, no server call):
```

```
  decision: BLOCK
```

```
  action: tool_call:wallet.transfer
```

```
  reason: amount=9999.0 exceeds cap 5 (unknown agent)
```

OAA is a small, independently published open specification (~150-line reference implementation, MIT licensed), used identically by this project and by agent-guardrail, a separate, general-purpose MCP policy

firewall by the same author.

5. Transaction Construction: Known Failure Mode and Fix

Guardian optionally constructs the raw calldata for transfer, approve, swap, and a scoped set of bridge deposits, so its simulation stage can dry-run the real transaction rather than a synthetic stand-in. Building this uncovered a genuine, previously unnoticed correctness bug worth documenting directly, in the interest of transparency about what "tested" has actually meant at each stage of this project.

The simulation stage was dry-running its verification call against the address encoded as the transaction's semantic target — for an ERC-20 transfer or approve, that is the recipient or spender parameter, not the token contract actually being invoked. Calling an ordinary externally-owned account with arbitrary calldata succeeds silently on Ethereum, with no revert — meaning the simulation stage could never have caught a real transfer or approve failure against a normal wallet address, the most common case, despite passing every existing mocked test.

The fix makes the correct call target an explicit, separate field carried alongside the built transaction, rather than an implicit assumption about a semantically overloaded parameter, with regression tests asserting the real destination address per action type. The episode is retained here as a concrete illustration of why this paper avoids claiming any component is complete without a specific, checkable basis for the claim.

6. Ecosystem Integration

Because Guardian holds no keys and makes no assumption about the signing layer beneath it, it can sit in front of any agent wallet as an orchestration-level gate rather than a modification to that wallet's own pipeline. A reference integration ships as a standard Agent Skill (the same open skill format used by MetaMask's own Agent Wallet CLI): the calling agent consults Guardian before executing any fund-moving command, and proceeds only on an ALLOW decision.

Destination	Support
Any EVM chain (evaluation)	Yes — chain-agnostic by design
Uniswap V2 (swap)	Yes — real on-chain quote, required slippage bound
Base (L1→L2 bridge deposit)	Yes — official OP Stack bridge only
Other bridge protocols / L2→L1 withdrawal	Not yet built
Session keys / account abstraction / key custody	Deliberately out of scope

7. Honest Status

As of this writing, 131 tests pass across the suite, and the claims in this paper describing live behavior (intent verification output, OAA tokens, real-provider signals) were each independently re-run, not reproduced from documentation. The following remain open by design or by capacity, not by oversight:

- No independent security audit has been performed on the policy engine or risk fusion logic.
- `malicious_contracts.json` / `verified_contracts.json` ship empty — no single authoritative source exists to seed them the way OFAC's list does for sanctioned addresses, and the project declines to guess.
- Persistent storage beyond single-instance SQLite (Postgres/Redis for multi-replica deployments) is not yet built.
- Bridge support covers one destination (Base) and deposits only; other chains and withdrawal flows are open.

8. Conclusion

Agentic Wallet Guardian is not an attempt to compete with custody-and-execution platforms such as Coinbase's Agentic Wallets or MetaMask's own Agent Wallet — both are well-resourced, purpose-built products in that layer. It occupies a narrower, complementary position: an independent, auditable, vendor-neutral decision gate that any agent wallet can be asked to consult before it signs, with every decision independently verifiable after the fact.

Source, tests, and this paper's underlying commit history:
github.com/rudimentall1/agentic-wallet-guardian-v3